ONE-PAGE BRIEF

Post-quantum cryptography review: zcash-android-wallet-sdk @ a95780ac00e0

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/zcash-android-wallet-sdk, commit `a95780ac00e0` · Reviewed: 2026-10-29 23:51 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **0** High **7** Medium
20 Low **6** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-07378	**Quantum-vulnerable RSA key (2048-bit) in responsible_disclosure.md** What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it..
Medium QSI-2026-07377	**SHA-1 used in backend-lib/src/main/java/cash/z/ecc/android/sdk/internal/ext/FileExt.kt** confirmed by the analyst What to do: Replace with SHA-256/SHA-3 (or Argon2/bcrypt for passwords) where security-relevant.
Medium QSI-2026-07382	**block-buffer 0.10.4 is affected by GHSA-qwgh-2vcv-g2f7** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).
Medium QSI-2026-07383	**block-buffer 0.11.0-rc.3 is affected by GHSA-qwgh-2vcv-g2f7** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).
Medium QSI-2026-07387	**rsa 0.9.10 is affected by RUSTSEC-2023-0071 (CVE-2023-49092)** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).
Medium QSI-2026-07388	**rustls 0.23.43 is affected by GHSA-2mjx-qc3c-rqvc (RUSTSEC-2026-0285)** What to do: Upgrade to a fixed version (0.23.45).

21 more in the full report.

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 26; unlikely to apply to this build: 16 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 10.

Analyst review: 1 confirmed, 0 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-23)

Static review of source code and manifests; files analysed: 350. No requests were sent to the owner's systems.

Full report, content SHA-256: `43fe44930c5d9740d0636d44e34f8b5273e8b1fbfa15a919571b0af653f76cc1`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.